

PROYECTO INTEGRADO

Ciclo Formativo de Administración de Sistemas en Red

Instalación y Administración de un Sistema de Detección y Prevención de Intrusiones (IDS/IPS) con Suricata, Alta Disponibilidad con HAProxy y Alertas Automatizadas

Alumno	César Acevedo Gomez
Centro	IES Fuengirola 1
Ciclo	Administración de Sistemas en Red (ASIR)
Módulo	Proyecto Integrado
Curso	2025 / 2026
Fecha	Junio 2026

1. INFORMACIÓN GENERAL

Campo	Descripción
Alumno	César Acevedo Gomez
Título	Instalación y Administración de un Sistema de Detección y Prevención de Intrusiones (IDS/IPS) con Suricata, Alta Disponibilidad con HAProxy y Alertas Automatizadas
Tecnología principal	Suricata IDS/IPS + HAProxy + Nginx + Fail2ban
Sistema operativo	Debian 13 (Trixie)
Virtualización	VirtualBox

2. INTRODUCCIÓN

Ante el aumento constante de ciberataques, incluyendo software malicioso, suplantación de identidad, ataques de fuerza bruta y robo de datos, es esencial poner en marcha métodos activos para detectar, alertar y responder a estas amenazas en tiempo real.

Este proyecto parte de la propuesta inicial del instituto, que sugería instalar un sistema de detección de intrusiones junto con un honeypot. Sin embargo, la propuesta ha evolucionado significativamente: se ha sustituido Snort por Suricata (motor IDS/IPS más moderno y eficiente), se ha añadido alta disponibilidad mediante HAProxy con servidor secundario de respaldo, y se ha implementado un sistema completo de prevención de intrusiones integrando Suricata con Fail2ban para el bloqueo automático de IPs atacantes.

Las principales aportaciones originales de este proyecto respecto a trabajos similares son:

- Integración completa IDS/IPS: Suricata detecta el ataque, Fail2ban lo bloquea automáticamente.
- Alertas en tiempo real a Telegram y Email mediante scripts Python propios.
- Alta disponibilidad real: HAProxy balancea entre servidor principal y secundario — si uno cae, el otro toma el relevo automáticamente.
- Reglas personalizadas para detección de ataques web: SQL Injection, XSS y Directory Traversal.
- Todo desplegado en Debian 13, la versión más reciente, con servicios configurados como daemons del sistema.

3. OBJETIVOS

3.1 Objetivo Principal

Diseñar, implementar y validar una infraestructura de seguridad de red completa sobre Debian 13 en entorno virtualizado, que incluya detección y prevención de intrusiones, alta disponibilidad web y alertas automatizadas.

3.2 Objetivos Específicos

- Instalar y configurar Suricata como sistema IDS/IPS, monitorizando el tráfico de red en tiempo real y detectando anomalías como escaneos de puertos, ataques de fuerza bruta, SQL Injection y XSS.
- Desarrollar reglas personalizadas de Suricata para la detección de ataques específicos: escaneos Nmap, fuerza bruta SSH, inyección SQL, Cross-Site Scripting (XSS) y Directory Traversal.
- Implementar un sistema de alertas automatizadas mediante scripts Python que notifiquen por Telegram y Email en tiempo real cuando Suricata detecte una amenaza.
- Configurar Fail2ban integrado con Suricata para el bloqueo automático de IPs atacantes, convirtiendo el sistema de IDS (detección) a IPS (prevención).
- Desplegar Nginx como servidor web principal con una página funcional del proyecto.
- Instalar un servidor Nginx secundario de respaldo y configurar HAProxy para balanceo de carga con failover automático, garantizando alta disponibilidad.
- Configurar UFW como cortafuegos complementario al sistema IDS/IPS.
- Realizar pruebas de validación simulando ataques reales: escaneos Nmap, fuerza bruta SSH, SQL Injection, XSS y Directory Traversal.
- Documentar todo el proceso con diagramas de arquitectura y capturas de funcionamiento real.

4. ARQUITECTURA DEL SISTEMA

4.1 Diagrama de la Infraestructura

La infraestructura se compone de dos máquinas virtuales Debian 13 interconectadas mediante red interna de VirtualBox, con acceso a internet a través de NAT y conectividad con el equipo host mediante adaptador puente:

Componente	VM	IP	Función
Suricata IDS/IPS	VM Principal	192.168.1.35	Detección y prevención de intrusiones
Nginx Principal	VM Principal	192.168.1.35:80	Servidor web primario
HAProxy	VM Principal	192.168.1.35:8080	Balanceo de carga y alta disponibilidad
Fail2ban	VM Principal	192.168.1.35	Bloqueo automático de IPs atacantes
Script Alertas	VM Principal	192.168.1.35	Notificaciones Telegram y Email
Nginx Secundario	VM Secundaria	192.168.232.2:80	Servidor web de respaldo (backup)

4.2 Flujo de Tráfico

El flujo de tráfico en el sistema sigue la siguiente secuencia:

- El atacante lanza un ataque contra la IP del servidor (192.168.1.35).
- HAProxy recibe el tráfico en el puerto 8080 y lo redirige al servidor Nginx activo.
- Suricata analiza todo el tráfico en tiempo real en la interfaz de red.
- Si Suricata detecta una amenaza, escribe una alerta en /var/log/suricata/fast.log.
- El script Python detecta la nueva alerta y envía notificaciones a Telegram y Email.
- Fail2ban lee el fast.log y bloquea automáticamente la IP atacante mediante iptables.
- Si el servidor principal cae, HAProxy redirige automáticamente el tráfico al servidor secundario.

4.3 Red de VirtualBox

Adaptador	Tipo	Red	Uso
enp0s3	NAT	10.0.2.x	Acceso a internet
enp0s8	Red interna	192.168.232.x	Comunicación entre VMs
enp0s9	Adaptador puente	192.168.1.x	Acceso desde Windows/red local

5. ENTORNO TECNOLÓGICO

5.1 Tecnologías Empleadas

Tecnología	Versión	Función
Debian	13 (Trixie)	Sistema operativo base de ambas VMs
Suricata	7.0.10	Motor IDS/IPS — detección de intrusiones
Nginx	1.26.3	Servidor web principal y secundario
HAProxy	3.0.11	Balanceador de carga y alta disponibilidad
Fail2ban	1.1.0	Prevención de intrusiones — bloqueo de IPs
Python	3.x	Scripts de alertas automatizadas
UFW	0.36	Cortafuegos del sistema
iptables	integrado	Baneos de IPs por Fail2ban
VirtualBox	7.x	Plataforma de virtualización
Nmap	7.95	Herramienta de pruebas de ataque

5.2 Recursos Hardware

Recurso	Especificación
Procesador host	AMD Ryzen 5 3600 — 6 núcleos / 12 hilos a 3.95 GHz
RAM host	16 GB DDR4
VM Principal RAM	6 GB asignados
VM Secundaria RAM	4 GB asignados
VM Principal disco	30 GB SSD virtual
VM Secundaria disco	15 GB SSD virtual

5.3 Software Adicional

- Draw.io — Diagramas de arquitectura de red.
- MobaXterm — Cliente SSH para administración remota de las VMs.
- Telegram — Bot de alertas del sistema IDS.
- Gmail (SMTP SSL) — Envío de alertas por correo electrónico.

6. IMPLEMENTACIÓN

6.1 Suricata IDS/IPS

Se instaló Suricata 7.0.10 en Debian 13 y se configuró para escuchar en la interfaz `enp0s9`, que es la que recibe el tráfico externo desde la red local. Se descargaron y actualizaron las reglas oficiales mediante `suricata-update`, y se crearon reglas personalizadas en `/etc/suricata/rules/local.rules` para la detección de:

- Escaneos de puertos con Nmap (flags SYN).
- Ataques de fuerza bruta SSH.
- Ataques HTTP: SQL Injection (UNION SELECT, OR 1=1, DROP TABLE).
- Cross-Site Scripting — XSS (etiquetas `<script>`, `javascript:`, `onerror=`).
- Directory Traversal (`../`), acceso a `/admin`, `/etc/passwd`.
- Detección ICMP flood.

6.2 Sistema de Alertas — Telegram y Email

Se desarrolló un script Python propio (`/opt/ids-alertas/alertas.py`) que monitoriza en tiempo real el fichero `/var/log/suricata/fast.log`. Cuando Suricata escribe una nueva alerta, el script la detecta y envía simultáneamente:

- Notificación a Telegram mediante la API oficial del Bot (token + chat_id).
- Correo electrónico mediante SMTP SSL a través de Gmail con contraseña de aplicación.

El script se configuró como servicio `systemd` (`ids-alertas.service`) para que arranque automáticamente con el sistema.

6.3 Nginx — Servidor Web

Se instaló Nginx en ambas VMs. El servidor principal aloja una página web del proyecto en `/var/www/html/index.html`. El servidor secundario aloja una página de respaldo con fondo naranja diferenciado, que permite identificar visualmente cuándo HAProxy ha realizado el failover.

6.4 HAProxy — Balanceo de Carga y Alta Disponibilidad

Se configuró HAProxy 3.0.11 en la VM Principal escuchando en el puerto 8080. La configuración define un backend con dos servidores:

- `nginx_principal` (127.0.0.1:80) — Servidor activo principal con health check.
- `nginx_secundario` (192.168.232.2:80) — Servidor de respaldo (backup), se activa automáticamente si el principal falla.

El balanceo usa el algoritmo `roundrobin` con opción `httpchk` para verificar la disponibilidad de los servidores en tiempo real.

6.5 Fail2ban — Prevención de Intrusiones

Se configuró Fail2ban con dos jails activas:

- `sshd` — Banea IPs que superen 5 intentos fallidos de autenticación SSH en 10 minutos.
- `suricata` — Lee el `fast.log` de Suricata y banea automáticamente IPs que generen 10 o más alertas en 30 segundos.

El sistema utiliza iptables-multiport como acción de baneo, bloqueando los puertos 80, 8080 y 22. La `whitelist` incluye la subred 192.168.1.0/24 para evitar bloqueos accidentales del administrador. El tiempo de baneo es de 1 hora por defecto.

6.6 UFW — Cortafuegos

Se configuró UFW como cortafuegos complementario, con las siguientes reglas activas:

Puerto	Protocolo	Acción	Origen
22	TCP	ALLOW	Anywhere
80	TCP	ALLOW	Anywhere
443	TCP	ALLOW	Anywhere
8080	TCP	ALLOW	Anywhere

7. PRUEBAS DE VALIDACIÓN

7.1 Resumen de Pruebas Realizadas

Prueba	Herramienta	Resultado Esperado	Resultado
Escaneo de puertos	Nmap -sS	Alerta en fast.log + Telegram	OK
Fuerza bruta SSH	SSH intentos fallidos	IP baneada por Fail2ban	OK
SQL Injection	Navegador / curl	Alerta SQL Injection en Telegram	OK
XSS	Navegador	Alerta XSS en Telegram	OK
Directory Traversal	curl /../etc/passwd	Alerta en fast.log	OK
Alta disponibilidad	Stop nginx principal	Web sigue desde secundario	OK
Bloqueo automatico	Multiples alertas Suricata	IP baneada por Fail2ban	OK
Alertas Email	Cualquier ataque	Email recibido en Gmail	OK

7.2 Demostración de Alta Disponibilidad

Se comprobó que al detener el servicio Nginx en el servidor principal (`systemctl stop nginx`), HAProxy detecta el fallo en el siguiente health check y redirige automáticamente todo el tráfico al servidor secundario. La web sigue siendo accesible desde `http://192.168.1.35:8080` sin interrupción perceptible para el usuario.

7.3 Demostración IDS/IPS

Se lanzaron ataques reales desde Windows (Nmap, intentos SSH, peticiones HTTP maliciosas) contra la IP 192.168.1.35. Suricata detectó todos los ataques, las alertas llegaron en tiempo real a Telegram y Email, y Fail2ban bloqueó automáticamente la IP atacante tras superar el umbral configurado.

8. CRONOGRAMA

Fase	Descripción	Período
Fase 1	Investigación, planificación y selección de tecnologías	Nov 18 — Dic 8, 2025
Fase 2	Instalación de VMs, configuración de red y Suricata	Dic 9, 2025 — Ene 5, 2026
Fase 3	Nginx, HAProxy, servidor secundario y alta disponibilidad	Ene 6 — Feb 2, 2026
Fase 4	Scripts Python, bot Telegram, alertas Email y Fail2ban	Feb 3 — Feb 23, 2026
Fase 5	Pruebas de validación, simulación de ataques y ajustes	Feb 24 — Mar 15, 2026
Fase 6	Documentación, diagramas y preparación de la presentación	Mar 16 — Jun 12, 2026

9. REFERENCIAS

- Documentación oficial de Suricata: <https://suricata.io/documentation/> — Guías de instalación, configuración y reglas.
- Documentación oficial de HAProxy: <https://www.haproxy.org/> — Configuración de balanceo y health checks.
- Documentación oficial de Fail2ban: <https://github.com/fail2ban/fail2ban> — Configuración de jails y filtros.
- Telegram Bot API: <https://core.telegram.org/bots> — Guías para crear y configurar bots.
- OWASP (Open Web Application Security Project): <https://owasp.org/> — Mejores practicas en seguridad web.
- Repositorio de T-Pot: <https://github.com/telekom-security/tpotce> — Referencia para honeypots.
- Debian 13 Trixie: <https://www.debian.org/> — Documentacion del sistema operativo.
- Nmap Network Scanning: <https://nmap.org/book/> — Referencia para pruebas de penetracion.
- Blogs educativos: Aprobare.es y DavidDelRio.es — Ejemplos similares en ASIR.
- IES San Clemente: Proyectos de ASIR — Idea base del proyecto.

10. CONCLUSIONES

El proyecto ha superado los objetivos iniciales planteados en la propuesta original. Se partía de la idea de instalar un IDS básico con Snort y un honeypot, y se ha llegado a implementar una infraestructura de seguridad completa y funcional que incluye:

- Un sistema IDS/IPS real con Suricata, con reglas personalizadas para detectar los ataques más comunes en entornos web y de red.
- Un sistema de alertas en tiempo real a Telegram y Email, totalmente automatizado mediante servicios del sistema.
- Una arquitectura de alta disponibilidad con HAProxy y servidor de respaldo, que garantiza la continuidad del servicio ante fallos.
- Un sistema de prevención activa mediante la integración de Suricata con Fail2ban, que bloquea automáticamente a los atacantes.

Este proyecto demuestra que es posible implementar una solución de seguridad de nivel profesional con herramientas de código abierto, sobre hardware modesto y en un entorno virtualizado, lo que lo hace perfectamente aplicable en entornos reales como PYMES o redes de pequeñas empresas.

Como mejoras futuras se plantean: la implementación de HTTPS con certificados Let's Encrypt, la integración de un dashboard web para visualización de alertas en tiempo real, y la incorporación de T-Pot como honeypot dedicado para atraer y analizar ataques externos.